MITRE ATLAS | AML.CS0037 - Data Exfiltration via Agent Tools in Copilot Studio

Entry Information

ID:
AML.CS0037

Type:
Case-Study

Name:
Data Exfiltration via Agent Tools in Copilot Studio

URL:
https://atlas.mitre.org/studies/AML.CS0037/

Incident Date:
2025-06-01

Target:
Copilot Studio Customer Service Agent

Actor:
Zenity

Description

Researchers from Zenity demonstrated how an organization’s data can be exfiltrated via prompt injections that target an AI-powered customer service agent.

The target system is a customer service agent built by Zenity in Copilot Studio. It is modeled after an agent built by McKinsey to streamline its customer service needs. The AI agent listens to a customer service email inbox where customers send their engagement requests. Upon receiving a request, the agent looks at the customer’s previous engagements, understands who the best consultant for the case is, and proceeds to send an email to the respective consultant regarding the request, including all of the relevant context the consultant will need to properly engage with the customer.

The Zenity researchers begin by performing targeting to identify an email inbox that is managed by an AI agent. Then they use prompt injections to discover details about the AI agent, such as its knowledge sources and tools. Once they understand the AI agent’s capabilities, the researchers are able to craft a prompt that retrieves private customer data from the organization’s RAG database and CRM, and exfiltrate it via the AI agent’s email tool.

Vendor Response: Microsoft quickly acknowledged and fixed the issue. The prompts used by the Zenity researchers in this exercise no longer work, however other prompts may still be effective.

Attack Procedure:
[AML.T0006] Active Scanning: The researchers look for support email addresses on the target organization’s website which may be managed by an AI agent. Then, they probe the system by sending emails and looking for indications of agentic AI in automatic replies.
[AML.T0065] LLM Prompt Crafting: Once a target has been identified, the researchers craft prompts designed to probe for a potential AI agent monitoring the inbox. The prompt instructs the agent to send an email reply to an address of the researchers’ choosing.
[AML.T0093] Prompt Infiltration via Public-Facing Application: The researchers send an email with the

malicious prompt to the inbox they suspect may be managed by an AI agent.
[AML.T0051.002] Triggered: The researchers receive a reply at the address they specified, indicating that there is an AI agent present, and that the triggered prompt injection was successful.
[AML.T0084.002] Activation Triggers: The researchers infer that the AI agent is activated when receiving an email.
[AML.T0084.001] Tool Definitions: The researchers infer that the AI agent has a tool for sending emails.
[AML.T0047] AI-Enabled Product or Service: From here, the researchers repeat the same steps to interact with the AI agent, sending malicious prompts to the agent via email and receiving responses at their desired address.
[AML.T0051] LLM Prompt Injection: The researchers modify the original prompt to discover other knowledge sources and tools that may have data they are after.
[AML.T0084.000] Embedded Knowledge: The researchers discover the AI agent has access to a “Customer Support Account Owners.csv” data source.
[AML.T0084.001] Tool Definitions: The researchers discover the AI agent has access to the Salesforce get-records tool, which can be used to retrieve CRM records.
[AML.T0065] LLM Prompt Crafting: The researchers put their knowledge of the AI agent’s tools and knowledge sources together to craft a prompt that will collect and exfiltrate the customer data they are after.
[AML.T0085.000] RAG Databases: The prompt asks the agent to retrieve all of the fields and rows from “Customer Support Account Owners.csv”. The agent retrieves the entire file.
[AML.T0085.001] AI Agent Tools: The prompt asks the agent to retrieve all Salesforce records using its get-records tool. The agent retrieves all records from the victim’s CRM.
[AML.T0086] Exfiltration via AI Agent Tool Invocation: The prompt asks the agent to email the results to an address of the researcher’s choosing using its email tool. The researchers successfully exfiltrate their target data via the tool invocation.

References

- AgentFlayer: Discovery Phase of AI Agents in Copilot Studio — https://labs.zenity.io/p/a-copilot-studio-story-discovery-phase-in-ai-agents-f917

- AgentFlayer: When AIjacking Leads to Full Data Exfiltration in Copilot Studio — https://labs.zenity.io/p/a-copilot-studio-story-2-when-aijacking-leads-to-full-data-exfiltration-bc4a